KOJI — Réponses aux informations requises avant rédaction (v0.2)

Document destiné au juriste — ABL Expert Renov, SAS, RCS Paris 992 204 651

Documents concernés : CGU, CGV, Conditions de l'essai gratuit, Politique de confidentialité, Registre RGPD, Contrat de sous-traitance art. 28.

Rédigé par : équipe développement (Amira / Firas), en réponse au questionnaire du 6 août 2026. Date des constats : 11 août 2026.

> **Portée de ce document.** Le Bloc A répond aux 12 points techniques à partir d'une lecture directe du code source (fichiers et lignes cités en preuve) : ce qui est décrit est ce que le code fait aujourd'hui, y compris quand la réponse est défavorable. Les Blocs B (décisions) et C (pièces externes) ont été complétés le 11 août 2026 par la direction (Amira) ; certains points restent volontairement ouverts (« à définir ») et devront être arrêtés avant la rédaction définitive.

> **Avertissement.** Les numéros de ligne peuvent avoir changé si le code a évolué entre la date de cet audit et la lecture de ce document. En cas de doute sur un point précis, redemander une vérification à jour avant rédaction définitive.

Résumé exécutif — failles de sécurité actives constatées pendant l'audit

L'audit mené pour répondre au questionnaire a fait remonter des vulnérabilités réelles et exploitables, au-delà du périmètre des 24 points. Elles sont directement pertinentes pour le juriste car elles contredisent ce que les documents pourraient être tentés d'affirmer (cloisonnement des données, sécurité des mots de passe). Le développement recommande de ne pas publier de politique de confidentialité affirmant un niveau de sécurité non atteint tant que ces points ne sont pas corrigés.

1. **Fuite de données entre entreprises clientes** — le paramètre d'identification utilisateur (`userId`) transmis par le navigateur n'est pas vérifié contre la session authentifiée sur la majorité des routes de l'application. Modifier ce paramètre dans une requête permet de lire les données d'une autre entreprise cliente.
2. **Row Level Security neutralisée** sur la table qui contient la quasi-totalité des données personnelles (`koji_web_state`) : les politiques d'accès sont réglées pour autoriser tout le monde (`USING (true)`) avec la clé publique du projet.
3. **Plusieurs routes API ne vérifient aucune authentification**, dont une qui renvoie les devis de n'importe quel client à partir de son adresse e-mail passée en clair dans l'URL.
4. **Mots de passe du portail client stockés et transmis en clair** (base de données, e-mails, notifications, réponse d'API), à la différence des mots de passe des comptes ouvriers qui sont hachés (mais avec un algorithme simple, non recommandé pour ce type de données).
5. **Le fichier contenant une copie complète de la base de données de développement est versionné dans le dépôt Git**, avec des données réelles et plusieurs mots de passe en clair, dont celui du compte administrateur.
6. **Aucune protection centralisée des routes** (pas de middleware d'authentification) ; la session est stockée côté navigateur dans un espace accessible à tout script exécuté sur la page.

Ces six points ne font pas partie des 24 questions du document d'origine mais conditionnent la sincérité de plusieurs affirmations que la politique de confidentialité et le contrat de sous-traitance devront contenir (art. 28, 32 RGPD). Le développement recommande de les traiter avant la mise en production ou, à défaut, de les documenter comme des risques connus et des chantiers en cours dans le registre RGPD.

BLOC A — Faits techniques (réponses complètes)

A1 — Plan Vercel du projet KOJI

Constat : indéterminable depuis le code source (aucun `vercel.json`, aucune configuration de déploiement dans le dépôt) — confirmé directement par la direction/le développement à partir de la console Vercel.

Conséquence : le plan étant Enterprise, l'addendum de traitement des données Vercel s'applique : un contrat de sous-traitance au sens de l'art. 28 RGPD existe bien avec cet hébergeur. Il reste à en obtenir une copie signée/acceptée pour le dossier.

> Plan : **Enterprise** / Date de souscription : à préciser / Addendum de traitement des données à joindre au dossier RGPD

A2 — Région d'hébergement Supabase

Constat : le projet Supabase est identifié (`hbgqbpyufaajqmedxodg.supabase.co`) ; la région n'apparaît pas dans le code (l'URL du projet ne la révèle pas) — confirmée directement à partir de la console Supabase.

Conséquence : hébergement en **eu-central-1 (Francfort, Allemagne)** — dans l'UE. Cela facilite la rédaction de la politique de confidentialité (pas de clauses contractuelles types nécessaires pour ce sous-traitant précis), à condition qu'une instruction écrite de localisation soit formalisée et conservée au dossier.

> Région : **eu-central-1 (Francfort)** / Instruction écrite de localisation : à rédiger et conserver au dossier

A3 — Prestataire d'e-mails transactionnels

Constat : les e-mails sont envoyés via SMTP Gmail direct (bibliothèque `nodemailer`), avec un compte Gmail (`lib/mailer.js:1,13-20`) — pas de service tiers dédié (Resend, Sendgrid, Brevo, Mailgun : aucun n'est intégré). La vérification du certificat TLS de la connexion SMTP est explicitement désactivée (`lib/mailer.js:19`, `rejectUnauthorized: false`).

Un seul type d'e-mail est réellement envoyé automatiquement par ce canal : l'accès au portail client après signature d'un devis (`app/api/signatures/[token]/route.js:151-159`). Le reste des identifiants (ouvriers, portail client avant signature) est affiché à l'écran ou partagé manuellement par l'utilisateur (copier-coller, WhatsApp, `mailto:`) — voir aussi A12.

Supabase Auth envoie séparément ses propres e-mails (confirmation de compte, réinitialisation de mot de passe), via l'infrastructure Supabase.

Conséquence pour le sous-traitant : le sous-traitant du canal e-mail est un compte Gmail personnel, pas un prestataire professionnel contractualisé. Ceci doit être corrigé avant de pouvoir documenter ce sous-traitant dans la politique de confidentialité et le registre.

A4 — Scripts tiers et traceurs réellement déposés

Constat : aucun traceur n'est présent. Recherche exhaustive négative sur : Vercel Analytics, Speed Insights, Google Fonts ou toute police distante, Google Tag Manager, pixels publicitaires, iframes, outils de mesure d'audience (Hotjar, Matomo, PostHog, Sentry). Aucun cookie n'est posé par l'application (aucun `document.cookie`, aucun `Set-Cookie`).

Le seul stockage côté navigateur est du `localStorage` / `sessionStorage` à usage strictement fonctionnel (session utilisateur, brouillons de devis/chantier, préférence de langue) — 11 clés recensées, aucune à finalité publicitaire.

Conséquence : aucun bandeau de consentement cookies n'est nécessaire dans l'état actuel du code. Ce constat devra être revérifié si un outil d'analyse est ajouté (le plan d'avancement en évoque un).

A5 — Comportement réel à la suppression d'un compte

Constat : cette fonctionnalité n'existe pas dans le code. Un libellé d'interface « Supprimer mon compte » / « Zone de danger » est traduit dans les fichiers de langue mais n'est relié à aucun bouton, aucune route API, aucune logique de suppression, physique ou logique.

Les suppressions unitaires qui existent par ailleurs (un chantier, un devis) suppriment l'enregistrement principal sans suppression en cascade : les documents, tâches, notifications et échanges liés à cet enregistrement restent en base, orphelins.

Conséquence : aucune politique de confidentialité ne peut aujourd'hui promettre un droit à l'effacement effectif (art. 17 RGPD). C'est un développement à prévoir avant publication, ou à formuler comme un chantier en cours dans le registre.

A6 — Périmètre et format de l'export de données

Constat : un utilisateur peut télécharger, un par un : un devis (PDF, et une variante « Word » qui est en réalité du HTML servi avec l'en-tête de fichier Word), les fournitures d'un devis, une facture (PDF), le relevé d'heures mensuel d'un ouvrier (PDF), un rapport d'intervention (PDF).

Aucun export global du compte n'existe (pas de CSV, pas de JSON structuré, pas de « tout télécharger »).

Conséquence : la portabilité au sens de l'art. 20 RGPD n'est couverte que partiellement, document par document, et seulement pour les documents listés ci-dessus.

A7 — Durée de rétention des journaux

Constat : un journal d'activité applicatif est bien conservé (`db.history` — actions comme création/modification/suppression de devis, ajout d'ouvrier, etc.), contenant des données personnelles en clair dans son contenu. Aucune purge automatique, aucun mécanisme de rétention ou d'expiration n'existe dans le code — ce journal grossit indéfiniment.

Les journaux techniques de Supabase et Vercel ne sont pas gérés par le code de l'application : aucun paramétrage personnalisé (log drain, export, purge programmée) n'existe dans ce dépôt. Leur durée de rétention dépend donc uniquement des politiques par défaut de ces plateformes, propres au plan souscrit (Enterprise pour Vercel — cf. A1).

> Réponse à compléter : durée exacte des politiques par défaut Vercel Enterprise et Supabase, à obtenir auprès de ces plateformes ou de leur documentation contractuelle.

A8 — Contenu du dossier de preuve de signature électronique

Constat : au moment de la signature d'un devis, sont enregistrés : nom du signataire, e-mail, téléphone, lieu, un message libre, et un horodatage.

Ne sont pas enregistrés : aucune image de signature graphique, aucune adresse IP, aucune empreinte (hash) du document signé, aucun identifiant de session. La case à cocher de consentement affichée au signataire est vérifiée au moment de la signature puis n'est pas conservée — rien ne prouve après coup qu'elle a été cochée.

Point de fragilité supplémentaire relevé pendant l'audit : une action existante (« renvoyer le devis ») permet de remettre un devis déjà signé en statut « en attente » sans vérifier qu'il est déjà signé, ce qui permet en théorie d'écraser une signature existante par une nouvelle. Ce comportement doit être corrigé avant que les CGU ne décrivent un mécanisme de preuve.

Conséquence : il s'agit d'une signature électronique simple, à force probante faible, sans les éléments qui en renforceraient la valeur en cas de contestation.

A9 — Chiffrement des documents et photos de chantier

Constat : aucun stockage de fichiers de type Supabase Storage ou système de fichiers n'est utilisé. Tous les fichiers déposés (photos, plans, logo d'entreprise, pièces jointes de chantier) sont convertis en base64 côté navigateur et stockés comme texte à l'intérieur du même enregistrement JSON que le reste des données de l'application.

Conséquence : la question de l'URL signée ou publique ne s'applique pas ici puisqu'il n'existe pas d'URL de fichier — mais il n'y a également aucune limite de taille, aucune expiration, et chaque lecture de l'application recharge l'ensemble de ces fichiers en mémoire. C'est un point d'architecture à signaler comme non conforme aux bonnes pratiques de l'art. 32 RGPD, indépendamment de la question initiale.

A10 — Cloisonnement entre entreprises clientes

Constat : mixte, et défaillant sur les deux volets.

Une minorité de fonctionnalités (chantiers, devis, fournitures, fournisseurs) passe par un accès Supabase authentifié par le jeton de l'utilisateur, censé être protégé par des politiques Row Level Security. Ces politiques ne sont pas présentes dans le dépôt de code (aucun dossier de migrations SQL) : leur existence et leur contenu ne peuvent pas être vérifiés depuis le code, seulement depuis la console Supabase.

La majorité des données de l'application (utilisateurs, ouvriers, clients, notifications, historique — voir A11) repose sur une table unique dont la Row Level Security est activée mais configurée pour tout autoriser à quiconque possède la clé publique du projet (clé nécessairement exposée au navigateur). Le filtrage réel repose alors uniquement sur du code applicatif, qui fait confiance à un identifiant utilisateur transmis par le navigateur sans le vérifier contre la session authentifiée.

Conséquence : dans l'état actuel, le cloisonnement entre deux entreprises clientes ne peut pas être affirmé dans la politique de confidentialité ni dans le contrat de sous-traitance proposé aux artisans. C'est le point le plus urgent à corriger.

A11 — Contenu de la table koji_web_state

Constat : cette table (une seule ligne, format JSON) contient la quasi-totalité des données personnelles de l'application : comptes utilisateurs, clients, ouvriers (dont numéro de sécurité sociale et image de pièce d'identité), heures travaillées, devis (dont mots de passe d'accès en clair), notifications, et les files internes d'e-mails/SMS en attente (contenant elles aussi des mots de passe en clair).

Un repli sur un fichier local existe et n'est conditionné par aucune variable d'environnement de type « production/développement » — il peut s'activer silencieusement en cas d'erreur de connexion à Supabase, y compris en production, avec un stockage non garanti dans le temps (dossier temporaire du serveur).

Point supplémentaire constaté : ce fichier local de secours contient une copie réelle des données et est actuellement suivi par Git (versionné dans l'historique du dépôt de code), avec des données personnelles réelles, dont plusieurs mots de passe en clair.

Conséquence : une partie substantielle des données personnelles échappe à toute politique de suppression ciblée, et une copie de sauvegarde de ces données existe dans un système (Git) qui n'est pas prévu pour en héberger.

A12 — Cycle de vie des identifiants ouvriers

Constat : l'identifiant et le mot de passe provisoire d'un ouvrier sont générés par un générateur aléatoire cryptographique (bonne pratique). En revanche, ils sont hachés avec un algorithme simple (SHA-256 à passe unique), non recommandé par les référentiels actuels pour ce type de secret (un algorithme dédié — bcrypt, argon2 — serait attendu), et le code prévoit un repli qui accepterait un mot de passe non haché s'il en trouvait un.

Aucune durée de validité n'est appliquée au mot de passe provisoire, et le changement de mot de passe à la première connexion n'est pas imposé, bien que le code prévoie un indicateur en ce sens — cet indicateur n'est simplement jamais vérifié.

La transmission ne se fait pas par envoi automatique : l'identifiant et le mot de passe sont affichés à l'écran à l'artisan, qui les transmet lui-même par le canal de son choix.

Conséquence : écart avec les recommandations CNIL sur les mots de passe temporaires (délibération n° 2022-100), sur un traitement portant sur des données de paie.

BLOC B — Décisions de la direction

Décisions arrêtées par la direction (Amira, pour le compte d'ABL Expert Renov) le 11 août 2026, en réponse au questionnaire du 6 août 2026.

B1 — Nature exacte du « Profil Particulier » (POINT BLOQUANT)

Le Profil Particulier désigne-t-il (A) le portail gratuit du client final de l'artisan, déjà développé, ou (B) une offre payante destinée aux particuliers ?

> Décision : **Option A** — le Profil Particulier est le portail gratuit du client final de l'artisan (module 15 du cahier des charges). Aucune offre payante n'est destinée aux particuliers. KOJI ne bascule donc pas dans le droit de la consommation intégral pour ce profil.

B2 — Nombre de formules, tarifs, HT ou TTC

Combien de formules sont réellement commercialisées, à quels prix, HT ou TTC ?

> Décision : constat tiré du code (`app/abonnement/page.jsx`) — **3 formules** actuellement affichées : **Koji GO** (19,99 €/mois — 4 devis, versions illimitées, PDF/Word, signature électronique, espace client particulier), **Koji Premium** (49,99 €/mois — devis illimités, marketplace, bibliothèque d'ouvrages avancée, gestion d'équipe, notifications SMS), **Koji Business** (99,99 €/mois — accès illimité, multi-utilisateurs, support prioritaire, intégration comptable, rapports personnalisés). **HT ou TTC non précisé dans l'interface — à trancher et afficher explicitement.** Aucun système de paiement n'est aujourd'hui branché (bouton « Choisir » sans intégration Stripe) : ces tarifs ne sont pas encore facturés en pratique.

B3 — Engagement, périodicité, modalités de résiliation

Abonnement sans engagement ou durée minimale ? Reconduction tacite ? Préavis ? Délai de récupération des données après résiliation ?

> Décision : **sans engagement, résiliable à tout moment**, pas de durée minimale. Délai de récupération des données après résiliation : à définir (non fixé à ce jour).

B4 — Sens exact de la « conversion automatique » en fin d'essai

À l'issue des 14 jours : redirection sans prélèvement, ou souscription déclenchée automatiquement ?

> Décision : **redirection vers la page d'abonnement, souscription manuelle, aucun prélèvement sans validation expresse du client.** Le plan d'avancement mentionnant une « conversion automatique » doit être corrigé en conséquence pour rester cohérent avec les CGV.

B5 — Périmètre exact de l'offre de lancement à -50 %

Réduction sur la première période, la première année, ou à vie ? Le compteur des 20 premiers clients est-il tenu ?

> Décision : réduction sur **la première période de facturation uniquement** (premier mois selon la formule choisie), puis tarif plein. Modalité de décompte des 20 premières places : à formaliser (compteur à tenir et vérifier).

B6 — Politique de remboursement

Remboursement en cas de résiliation en cours de période ? Au prorata ou pas de remboursement ? Geste commercial en cas d'indisponibilité prolongée ?

> Décision : **aucun remboursement** — la période déjà payée reste acquise, la résiliation prend effet à la fin de la période en cours. Geste commercial en cas d'indisponibilité prolongée : non prévu à ce stade.

B7 — Adresses de contact publiques

Quatre adresses à créer et relever : contact général, support, protection des données, signalement de contenu illicite. Sur quel domaine ?

> Constat (code) : aucune adresse dédiée sur un domaine de la société n'existe actuellement. Seules des adresses Gmail personnelles sont utilisées comme comptes admin (`bouhouchimira@gmail.com` , `ablexpertrenov@gmail.com` , `abaqueduc@gmail.com`) et comme expéditeur des e-mails applicatifs. **Décision à prendre :** nom de domaine et quatre adresses (contact/support/RGPD/signalement) à créer avant publication — non tranché à ce jour.

B8 — Matrice des durées de conservation

Durées à fixer pour : compte inactif, données d'un client final après achèvement du chantier, devis et factures, relevés d'heures des ouvriers, tickets de support, preuves de signature.

> Constat (code) : seules deux durées sont aujourd'hui fixées dans le code — expiration du lien de signature à 30 jours, essai gratuit à 14 jours. Le reste de la matrice n'est pas encore arrêté ; la direction a choisi de laisser ce tableau à compléter directement avec le juriste plutôt que de partir de valeurs par défaut proposées par le développement.

BLOC C — Pièces à obtenir à l'extérieur

Statuts confirmés par la direction le 11 août 2026. Ces démarches ne dépendent pas du code et doivent être lancées sans attendre.

C1 — Assurance RC Pro couvrant l'édition de logiciel

Déclarer cette activité nouvelle à l'assureur MIC (contrat actuel limité à contractant général / maître d'œuvre).

> Statut : **pas encore lancée.** À prioriser : le contrat actuel ne couvre aucun dommage lié au logiciel, et le défaut de déclaration expose à la nullité du contrat ou à la réduction proportionnelle de l'indemnité (art. L. 113-2, L. 113-8, L. 113-9 du code des assurances), y compris sur des sinistres de chantier sans rapport avec le logiciel.

C2 — Médiateur de la consommation

Uniquement si l'option B du point B1 est retenue. Adhérer à un dispositif agréé.

> Statut : **non nécessaire** — B1 a été tranché en option A (portail gratuit, pas d'offre payante aux particuliers). À réévaluer si cette décision change.

C3 — Dépôt de marque KOJI — finalisation et arbitrage classe 35

Recherche d'antériorité classes 9, 42, 35 ; vérification du titulaire (ABL EXPERT RENOV, SIREN 992 204 651) ; arbitrage sur l'ajout de la classe 35 ; vérifier que le nom de domaine est au nom de la société.

> Statut : **pas encore saisi** à l'INPI. La classe 35 n'apparaît pas nécessaire dans l'immédiat : B1 = option A exclut pour l'instant toute mise en relation commerciale entre particuliers et artisans. À confirmer avant dépôt (recherche d'antériorité classes 9 et 42 a minima, et vérification du nom de domaine au nom de la société).

C4 — Cession des droits d'auteur sur le code source

Contrats de cession de droits patrimoniaux signés par chaque développeur non salarié ayant contribué au code.

> Statut : le code a été écrit par Amira Bouhouchi (associée/dirigeante opérationnelle du projet). Firas Mzoughi (`firasmzoughi2001@gmail.com`) a contribué ponctuellement à quelques points bloquants, sans en être l'auteur principal — confirmé par l'historique Git (2 contributeurs identifiés). Statut de Firas vis-à-vis d'ABL Expert Renov (salarié ou prestataire) et existence d'une éventuelle cession écrite : à clarifier avec le juriste, qui appréciera si une cession est nécessaire au regard de l'ampleur de sa contribution.

Annexe — identité légale (rappel, déjà complète)
ABL EXPERT RENOV — SAS au capital de 50 000 euros — siège : 60 rue de l'Aqueduc, 75010 Paris — RCS Paris 992 204 651 — SIRET du siège : 992 204 651 00010 — TVA intracommunautaire : FR 88 992204651 — code APE 4399C — Président : André Beranger — Directeur général : Bilal Aghanim.